API Reference

QR Authenticity & Activation System v2.0

Base URL: `http://localhost:3000/api` **อัพเดตล่าสุด:** กุมภาพันธ์ 2026

---

1. Authentication

1.1 Login

```
POST /api/auth/login
```

Request Body:

```
{
  "username": "admin",
  "password": "admin123"
}
```

Response (200):

```
{
  "success": true,
  "data": {
    "user": {
      "id": 1,
      "username": "admin",
      "displayName": "Administrator",
      "role": "ADMIN"
    }
  }
}
```

Response (401):

```
{
  "success": false,
  "error": "Invalid credentials"
}
```

Notes:

- Sets `auth_token` cookie (HttpOnly, 7 days)
- Rate limited: 10 requests / 15 minutes

1.2 Logout

```
POST /api/auth/logout
```

Response (200):

```
{
  "success": true,
  "message": "Logged out successfully"
}
```

1.3 Get Current User

```
GET /api/auth/me
```

Headers:

- Cookie: `auth_token=...`

Response (200):

```
{
  "success": true,
  "data": {
    "id": 1,
    "username": "admin",
    "displayName": "Administrator",
    "role": "ADMIN"
  }
}
```

---

2. Public Endpoints (No Auth Required)

2.1 Verify Product

```
GET /api/public/verify?serial={serial12}
GET /api/public/verify?token={encrypted_token}
```

Query Parameters:

Parameter	Type	Description
serial	string	Serial 12 หลัก
token	string	Encrypted token (legacy)

Response (200) - Valid Product:

```json
{
  "success": true,
  "data": {
    "status": "GENUINE_SHIPPED",
    "serial": "123456789012",
    "product": {
      "name": "Filler XYZ 1ml",
      "sku": "FIL-001",
      "category": "Filler",
      "modelSize": "1ml",
      "lot": "LOT2026001",
      "expDate": "2027-12-31",
      "imageUrl": null
    },
    "clinic": {
      "name": "ABC Clinic",
      "province": "กรุงเทพมหานคร",
      "branchName": "สาขาสยาม"
    },
    "activation": null,
    "activationType": "SINGLE",
    "maxActivations": 1,
    "activationCount": 0,
    "canActivate": true
  }
}
```

Response (200) - Activated Product:

```json
{
  "success": true,
  "data": {
    "status": "ACTIVATED",
    "serial": "123456789012",
    "product": { ... },
    "activation": {
      "activatedAt": "2026-01-15T10:30:00Z",
      "activationNumber": 1
    },
    "canActivate": false
  }
}
```

Status Values:

Status	Description
`GENUINE_IN_STOCK`	ของแท้ - อยู่ในคลัง
`GENUINE_SHIPPED`	ของแท้ - ส่งออกแล้ว
`GENUINE_ACTIVATED`	ของแท้ - ถูก Activate แล้ว
`GENUINE_RETURNED`	ของแท้ - ถูกส่งคืนแล้ว
`TOKEN_REVOKED`	Token ถูกยกเลิก (มี QR ใหม่)
`INVALID`	ไม่พบในระบบ / ของปลอม

Rate Limit: 60 requests/minute

2.2 Activate Product

```
POST /api/public/activate
```

Request Body:

```json
{
  "serial": "123456789012",
  "customerName": "สมชาย ใจดี",
  "age": 35,
  "gender": "M",
  "province": "กรุงเทพมหานคร",
  "phone": "0812345678",
  "consent": true
}
```

Required Fields:

- `serial` - Serial 12 หลัก
- `consent` - ต้องเป็น true

Optional Fields:

- `customerName`, `age`, `gender`, `province`, `phone`

Response (200):

```
{
  "success": true,
  "data": {
    "serial": "123456789012",
    "activatedAt": "2026-01-15T10:30:00Z",
    "activationNumber": 1,
    "message": "Product activated successfully"
  }
}
```

Response (400) - Already Activated:

```
{
  "success": false,
  "error": "Product already activated"
}
```

Response (400) - Not Shipped:

```
{
  "success": false,
  "error": "Product must be shipped before activation"
}
```

Rate Limit: 60 requests/minute

2.3 Get Public Settings

```
GET /api/public/settings
```

Response (200):

```
{
  "success": true,
  "data": {
    "showClinicInfo": true,
    "requireCustomerInfo": false
  }
}
```

3. Warehouse Endpoints

Required Role: WAREHOUSE, MANAGER, ADMIN

3.1 GRN (Goods Received Note)

List GRN

```
GET /api/warehouse/grn
GET /api/warehouse/grn?page=1&limit=20&search=GRN-2026
```

Query Parameters:

Parameter	Type	Default	Description
page	number	1	หน้าที่
limit	number	20	จำนวนต่อหน้า
search	string	-	ค้นหา

Response (200):

```json
{
  "success": true,
  "data": {
    "items": [
      {
        "id": 1,
        "grnNo": "GRN-2026-000001",
        "receivedAt": "2026-01-15T09:00:00Z",
        "supplierName": "ABC Supplier",
        "warehouse": { "name": "คลังกลาง" },
        "receivedBy": { "displayName": "พนักงาน 1" },
        "_count": { "lines": 5 }
      }
    ],
    "pagination": {
      "page": 1,
      "limit": 20,
      "total": 100,
      "totalPages": 5
    }
  }
}
```

Create GRN

```
POST /api/warehouse/grn
```

Request Body:

```json
{
  "receivedAt": "2026-01-15T09:00:00Z",
  "warehouseId": 1,
  "supplierName": "ABC Supplier",
  "poNo": "PO-001",
  "deliveryNoteNo": "DN-001",
  "supplierAddress": "123 ถนน...",
  "supplierPhone": "02-xxx-xxxx",
  "supplierContact": "คุณ A",
  "deliveryDocDate": "2026-01-14",
  "remarks": "หมายเหตุ",
  "lines": [
    {
      "preGeneratedBatchId": 1,
      "serial12": "123456789012",
      "sku": "FIL-001",
      "itemName": "Filler XYZ 1ml",
      "categoryId": 1,
      "modelSize": "1ml",
      "unitId": 1,
      "lot": "LOT2026001",
      "mfgDate": "2025-01-01",
      "expDate": "2027-12-31",
      "inspectionStatus": "OK",
      "remarks": ""
    }
  ]
}
```

Response (201):

```json
{
  "success": true,
  "data": {
    "id": 1,
    "grnNo": "GRN-2026-000001",
    "lines": [...]
  }
}
```

Get GRN Detail

```
GET /api/warehouse/grn/{id}
```

Update GRN

```
PUT /api/warehouse/grn/{id}
```

Export GRN as PDF

```
GET /api/warehouse/grn/{id}/export
```

3.2 Pre-Generate QR

List Pre-Generated Batches

```
GET /api/warehouse/pre-generate
```

Create Pre-Generated Batch

```
POST /api/warehouse/pre-generate
```

Request Body:

```json
{
  "quantity": 100,
  "remarks": "Batch สำหรับ Filler"
}
```

Response (201):

```
{
  "success": true,
  "data": {
    "id": 1,
    "batchNo": "PG-2026-000001",
    "quantity": 100,
    "linkedCount": 0,
    "serials": [
      { "serial12": "123456789012", "qrUrl": "/v/123456789012" },
      ...
    ]
  }
}
```

Get Available Batches (for GRN)

```
GET /api/warehouse/pre-generate/available
```

Scan Pre-Generated QR

```
POST /api/warehouse/pre-generate/scan
```

Request Body:

```
{
  "serial": "123456789012"
}
```

Response (200):

```
{
  "success": true,
  "data": {
    "serial12": "123456789012",
    "status": "PENDING_LINK",
    "batch": {
      "id": 1,
      "batchNo": "PG-2026-000001"
    }
  }
}
```

3.3 Outbound

List Outbound

```
GET /api/warehouse/outbound
GET /api/warehouse/outbound?status=PENDING&clinicId=1
```

Query Parameters:

Parameter	Type	Description
status	string	DRAFT, PENDING, APPROVED, REJECTED
clinicId	number	Filter by clinic
page	number	หน้าที่
limit	number	จำนวนต่อหน้า

Create Outbound

```
POST /api/warehouse/outbound
```

Request Body:

```json
{
  "warehouseId": 1,
  "clinicId": 1,
  "shippingMethodId": 1,
  "purchaseOrderId": 1,
  "contractNo": "CON-001",
  "salesPersonName": "คุณ B",
  "companyContact": "02-xxx-xxxx",
  "clinicAddress": "456 ถนน...",
  "clinicPhone": "02-yyy-yyyy",
  "clinicEmail": "clinic@example.com",
  "clinicContactName": "คุณ C",
  "remarks": "หมายเหตุ",
  "lines": [
    {
      "productItemId": 1,
      "itemStatus": "สภาพปกติ"
    }
  ]
}
```

Update Outbound / Submit for Approval

```
PUT /api/warehouse/outbound/{id}
```

Request Body (Submit):

```json
{
  "action": "submit"
}
```

Request Body (Cancel):

```json
{
  "action": "cancel"
}
```

Export Outbound as PDF

```
GET /api/warehouse/outbound/{id}/export
```

3.4 Products

List Products

```
GET /api/warehouse/products
GET /api/warehouse/products?status=IN_STOCK&categoryId=1
```

Get Available Products (for Outbound)

```
GET /api/warehouse/products/available
```

Get Product Detail

```
GET /api/warehouse/products/{id}
```

Update Product

```
PUT /api/warehouse/products/{id}
```

3.5 Labels (PDF)

Generate QR Labels

```
POST /api/warehouse/labels
```

Request Body:

```
{
  "serials": ["123456789012", "123456789013", "123456789014"]
}
```

Response: PDF file (4x6 inch per label)

3.6 Reprint QR

Get Reprintable Products

```
GET /api/warehouse/reprint
GET /api/warehouse/reprint?search=123456
```

Reprint QR Code

```
POST /api/warehouse/reprint
```

Request Body:

```
{
  "serial": "123456789012",
  "reason": "Label เสียหาย"
}
```

Response (200):

```
{
  "success": true,
  "data": {
    "serial12": "123456789012",
    "newVersion": 2,
    "qrUrl": "/v/123456789012"
  }
}
```

Note: Token version +1, old token revoked

3.7 Return

Get Returnable Products

```
GET /api/warehouse/return
```

Return Product

```
POST /api/warehouse/return
```

Request Body:

```
{
  "serial": "123456789012",
  "reason": "สินค้าไม่ตรงตามสั่ง"
}
```

3.8 Damaged Products

List Damaged Products

```
GET /api/warehouse/damaged
```

Mark Product as Damaged

```
POST /api/warehouse/damaged
```

Request Body:

```
{
  "serial": "123456789012",
  "reason": "สินค้าแตก"
}
```

Update Damaged Product

```
PUT /api/warehouse/damaged/{id}
```

---

4. Manager Endpoints

Required Role: MANAGER, ADMIN

4.1 Approval Board

Get Pending Approvals

```
GET /api/manager/approval-board
GET /api/manager/approval-board?status=PENDING
```

Response (200):

```
{
  "success": true,
  "data": {
    "items": [
      {
        "id": 1,
        "deliveryNoteNo": "OUT-2026-000001",
        "status": "PENDING",
        "clinic": { "name": "ABC Clinic", "province": "กรุงเทพ" },
        "createdBy": { "displayName": "พนักงาน 1" },
        "createdAt": "2026-01-15T10:00:00Z",
        "_count": { "lines": 5 }
      }
    ],
    "counts": {
      "PENDING": 10,
      "APPROVED": 50,
      "REJECTED": 5
    }
  }
}
```

Approve Outbound

```
PUT /api/warehouse/outbound/{id}
```

Request Body:

```
{
  "action": "approve"
}
```

Reject Outbound

```
PUT /api/warehouse/outbound/{id}
```

Request Body:

```
{
  "action": "reject",
  "rejectReason": "ข้อมูลไม่ครบ"
}
```

---

5. Admin Endpoints

Required Role: ADMIN

5.1 Users

List Users

```
GET /api/admin/users
```

Create User

```
POST /api/admin/users
```

Request Body:

```
{
  "username": "newuser",
  "password": "password123",
  "displayName": "New User",
  "role": "WAREHOUSE"
}
```

Get User

```
GET /api/admin/users/{id}
```

Update User

```
PUT /api/admin/users/{id}
```

Reset Password

```
PUT /api/admin/users/{id}
```

Request Body:

```
{
  "action": "resetPassword",
  "newPassword": "newpassword123"
}
```

5.2 Clinics

List Clinics

```
GET /api/admin/clinics
```

Create Clinic

```
POST /api/admin/clinics
```

Request Body:

```
{
  "name": "ABC Clinic",
  "province": "กรุงเทพมหานคร",
  "branchName": "สาขาสยาม"
}
```

Get Clinic

```
GET /api/admin/clinics/{id}
```

Update Clinic

```
PUT /api/admin/clinics/{id}
```

Get Clinic Reservations

```
GET /api/admin/clinics/{id}/reservations
```

5.3 Product Masters

List Product Masters

```
GET /api/admin/masters/products
```

Create Product Master

```
POST /api/admin/masters/products
```

Request Body:

```
{
  "sku": "FIL-001",
  "nameTh": "ฟิลเลอร์ XYZ 1ml",
  "nameEn": "Filler XYZ 1ml",
  "categoryId": 1,
  "modelSize": "1ml",
  "description": "รายละเอียด",
  "defaultUnitId": 1,
  "activationType": "SINGLE",
  "maxActivations": 1
}
```

Get Product Master

```
GET /api/admin/masters/products/{id}
```

Update Product Master

```
PUT /api/admin/masters/products/{id}
```

5.4 Master Data (Categories, Units, etc.)

Categories

```
GET    /api/admin/masters/categories
POST   /api/admin/masters/categories
PUT    /api/admin/masters/categories/{id}
DELETE /api/admin/masters/categories/{id}
```

Units

```
GET    /api/admin/masters/units
POST   /api/admin/masters/units
PUT    /api/admin/masters/units/{id}
DELETE /api/admin/masters/units/{id}
```

Shipping Methods

```
GET    /api/admin/masters/shipping-methods
POST   /api/admin/masters/shipping-methods
PUT    /api/admin/masters/shipping-methods/{id}
DELETE /api/admin/masters/shipping-methods/{id}
```

Warehouses

```
GET    /api/admin/masters/warehouses
POST   /api/admin/masters/warehouses
PUT    /api/admin/masters/warehouses/{id}
DELETE /api/admin/masters/warehouses/{id}
```

5.5 Purchase Orders

List Purchase Orders

```
GET /api/admin/purchase-orders
GET /api/admin/purchase-orders?status=CONFIRMED&clinicId=1
```

Create Purchase Order

```
POST /api/admin/purchase-orders
```

Request Body:

```
{
  "clinicId": 1,
  "salesPersonName": "คุณ A",
  "companyContact": "02-xxx-xxxx",
  "clinicAddress": "456 ถนน...",
  "clinicPhone": "02-yyy-yyyy",
  "clinicEmail": "clinic@example.com",
  "clinicContactName": "คุณ B",
  "remarks": "หมายเหตุ",
  "lines": [
    {
      "productMasterId": 1,
      "quantity": 100
    }
  ]
}
```

Get Purchase Order

```
GET /api/admin/purchase-orders/{id}
```

Update Purchase Order

```
PUT /api/admin/purchase-orders/{id}
```

Confirm Purchase Order

```
PUT /api/admin/purchase-orders/{id}
```

Request Body:

```
{
  "action": "confirm"
}
```

5.6 System Settings

Get All Settings

```
GET /api/admin/system-settings
```

Update Setting

```
PUT /api/admin/system-settings
```

Request Body:

```
{
  "key": "verify.showClinicInfo",
  "value": true
}
```

5.7 Event Logs

List Event Logs

```
GET /api/admin/event-logs
GET /api/admin/event-logs?eventType=ACTIVATE&startDate=2026-01-01
```

Query Parameters:

Parameter	Type	Description
eventType	string	INBOUND, OUTBOUND, ACTIVATE, etc.
productItemId	number	Filter by product
userId	number	Filter by user
startDate	string	วันที่เริ่มต้น (YYYY-MM-DD)
endDate	string	วันที่สิ้นสุด (YYYY-MM-DD)
page	number	หน้าที่
limit	number	จำนวนต่อหน้า

5.8 File Upload

Upload Image

```
POST /api/admin/upload
Content-Type: multipart/form-data
```

Form Data:

- `file` - Image file (PNG, JPG, WebP)

Response (200):

```
{
  "success": true,
  "data": {
    "url": "/uploads/products/image-123.png"
  }
}
```

---

6. Health Check

```
GET /api/health
```

Response (200):

```
{
  "status": "ok",
  "timestamp": "2026-01-15T10:00:00Z",
  "database": "connected"
}
```

---

7. Error Response Format

All API errors follow this format:

```
{
  "success": false,
  "error": "Error message",
  "code": "ERROR_CODE"
}
```

Common Error Codes:

Code	HTTP Status	Description
`UNAUTHORIZED`	401	ไม่ได้ login
`FORBIDDEN`	403	ไม่มีสิทธิ์
`NOT_FOUND`	404	ไม่พบข้อมูล
`VALIDATION_ERROR`	400	ข้อมูลไม่ถูกต้อง
`RATE_LIMITED`	429	request เยอะเกินไป
`INTERNAL_ERROR`	500	Server error

---

8. Rate Limiting

Endpoint Type	Limit
Public (verify, activate)	60 requests/minute
Auth (login)	10 requests/15 minutes
Admin	100 requests/minute

Rate Limit Headers:

```
X-RateLimit-Limit: 60
X-RateLimit-Remaining: 59
X-RateLimit-Reset: 1705312800
```

---

9. Authentication

All protected endpoints require authentication via cookie:

```
Cookie: auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...
```

Cookie is automatically set after login and removed after logout.